

ENTERPRISE BUSINESS REQUIREMENTS DOCUMENTATION

AI-Powered Healthcare Medical Institution Platform

Business Requirements Document

Volume III of IV | Enterprise Architecture & Workflow Design

Document Title	AI-Powered Healthcare Medical Institution Platform — Business Requirements Document
Volume	Volume III of IV — Enterprise Architecture & Workflow Design
Document Version	1.0
Document Status	Draft for Executive Review
Classification	Confidential — Internal Use
Prepared For	Office of the Chief Information Officer / Chief Technology Officer
Prepared By	Enterprise Architecture & Digital Health Strategy
Date	September 2026
Total Pages	15

This document and its contents are confidential and proprietary. It is intended solely for authorized internal review and downstream architecture, design, and engineering planning, and does not itself constitute application source code or a certification of regulatory compliance.

Table of Contents

20. Overall Solution Architecture.....3

21. Enterprise Architecture Diagram.....6

22. Patient Workflow.....6

23. Hospital Workflow.....7

24. Administrative Workflow.....8

25. RBAC Workflow.....8

26. Responsible AI Workflow.....9

27. Data Flow Architecture.....9

28. Replit Integration Architecture.....10

29. Customized LLM Architecture.....12

30. Architectural Principles.....12

31. Architecture Decision Matrix & Executive Summary.....13

Document Revision History

VERSION	DATE	AUTHOR	DESCRIPTION
1.0	September 2026	Enterprise Architecture & Digital Health Strategy	Initial draft issued for executive review.

20. Overall Solution Architecture

The platform is organized into five architectural layers. Each layer has a distinct responsibility, and the Security Layer operates as a cross-cutting control plane enforced across all other layers rather than as a discrete step in the request path.

20.1 Presentation Layer

- Public Website
- Patient Interface
- Administrative Interface
- Dashboards
- Reporting Interface
- AI Interface

20.2 Application Layer

- Patient Management
- Healthcare Operations
- Administrative Management
- Reporting
- Analytics
- AI Services
- Authentication
- Authorization
- Workflow Management

20.3 AI Layer

- AI Orchestration
- Customized LLM
- Retrieval-Augmented Generation (RAG)
- Text-to-Image
- Text-to-Audio
- AI Narration
- AI Content Generation
- AI Validation
- AI Governance

20.4 Data Layer

- Patient Data
- PII
- PHI
- Audit Logs

- Analytics
- Reporting Data
- AI Knowledge Repository

20.5 Security Layer (Cross-Cutting)

- Identity
- Authentication
- RBAC
- Encryption
- Audit Logging
- Monitoring
- Threat Detection
- Governance

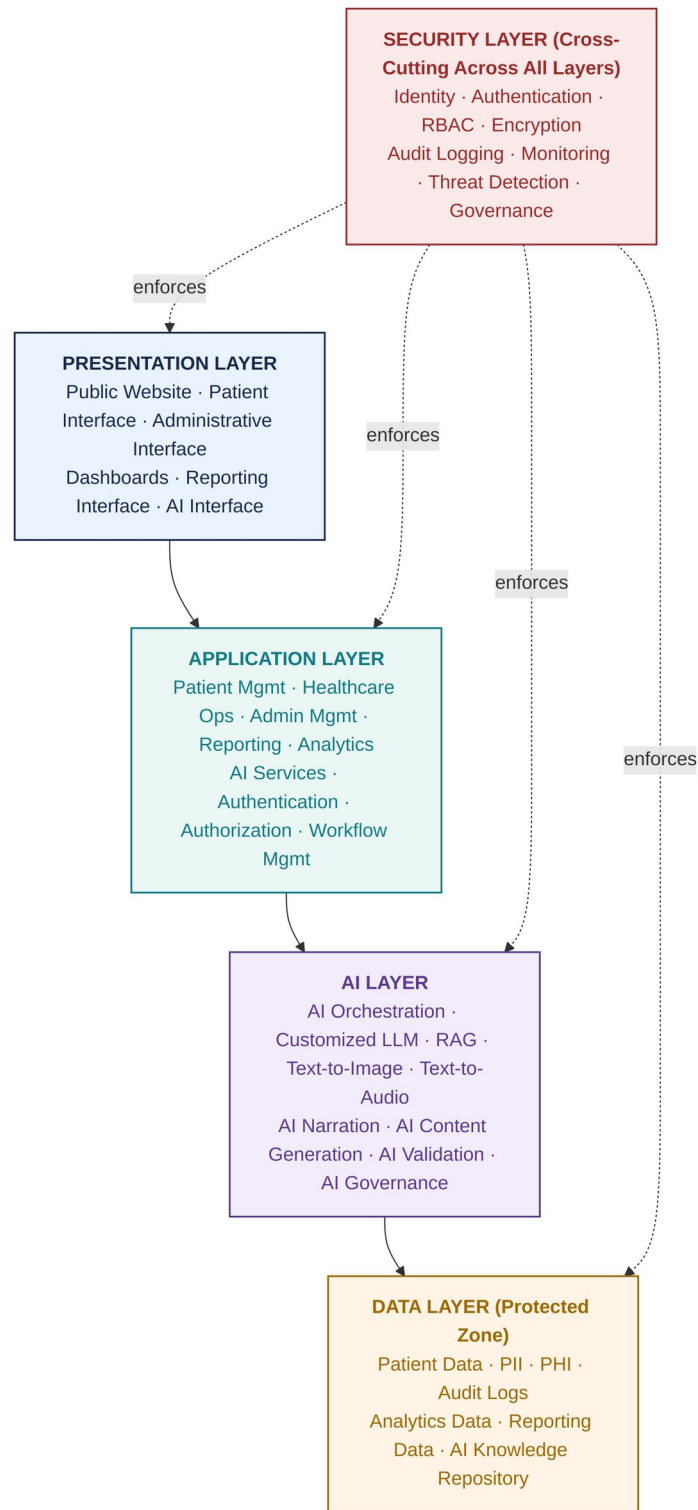


Figure 20.1 — Overall Layered Solution Architecture

21. Enterprise Architecture Diagram

The enterprise architecture diagram traces the primary request path — Users through the Web Application, Application Services, the Secure Data Layer, Analytics/Reporting, and the AI Layer — with Security & Governance enforced across every stage as a cross-cutting control rather than a single checkpoint.

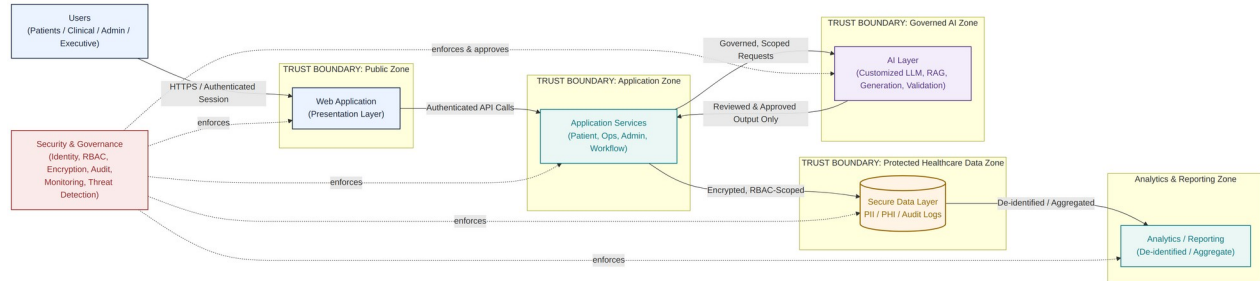


Figure 21.1 — Enterprise Architecture with Trust Boundaries

21.1 Trust Boundaries and Protected Zones

ZONE	CONTAINS	BOUNDARY CONTROL
Public Zone	Web Application (Presentation Layer)	Publicly reachable; no PHI/PII rendered prior to authentication.
Application Zone	Application Services (Patient, Ops, Admin, Workflow)	Authenticated-only; enforces RBAC before any downstream call.
Protected Healthcare Data Zone	Secure Data Layer (PII / PHI / Audit Logs)	Highest-sensitivity zone; encrypted, RBAC-scoped, fully audited access only.
Analytics & Reporting Zone	Analytics / Reporting	Operates on de-identified/aggregated data wherever feasible.
Governed AI Zone	AI Layer (Customized LLM, RAG, Generation, Validation)	Receives only governed, scoped requests; returns only reviewed/approved output to the Application Zone.

22. Patient Workflow

Registration → Identification → Check-In → Initial Assessment → Diagnosis Information → Monitoring → Medication → Admission if Required → Ongoing Monitoring → Discharge → Checkout → Historical Record.

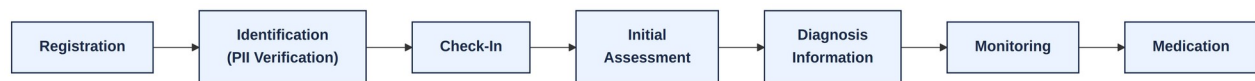


Figure 22.1a — Patient Workflow (Part 1 of 2): Registration through Medication

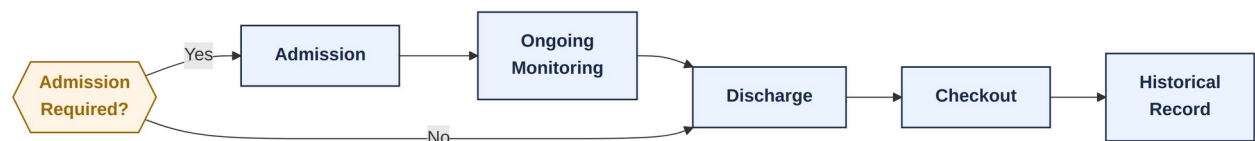


Figure 22.1b — Patient Workflow (Part 2 of 2): Admission Decision through Historical Record

22.1 Responsible Roles and Decision Points

STEP	RESPONSIBLE ROLE(S)	DECISION POINT
Registration	Admin / Clinical Staff	None
Identification (PII Verification)	Admin	None
Check-In	Admin / Clinical Staff	None
Initial Assessment	Nurse / Clinical Staff	None
Diagnosis Information	Physician	None
Monitoring	Nurse / Physician	None
Medication	Nurse (per physician order)	None
Admission Decision	Physician (clinical) / Admin (processing)	Decision Point: is inpatient admission required?
Ongoing Monitoring	Nurse / Physician	Applies only on the admission path
Discharge	Physician sign-off / Admin approval	None
Checkout	Admin / Clinical Staff	Convergence point for both admitted and non-admitted paths
Historical Record	System (audit-logged)	None

23. Hospital Workflow

Patient Arrival → Check-In → Triage → Clinical Evaluation → Diagnosis → Treatment → Medication → Monitoring → Admission → Discharge → Reporting → Historical Record.



Figure 23.1a — Hospital Workflow (Part 1 of 2): Arrival through Treatment

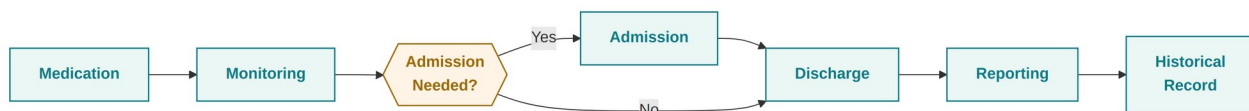


Figure 23.1b — Hospital Workflow (Part 2 of 2): Medication through Historical Record

23.1 Workflow Notes

- Triage introduces a severity decision point that determines the urgency and sequencing of Clinical Evaluation (e.g., ER-priority vs. routine).
- Admission is conditionally required based on clinical judgment following Monitoring; both the admission and non-admission paths converge at Discharge.
- Reporting captures the operational record of the encounter (throughput, timing, resource use) for institutional analytics, distinct from the clinical Historical Record.

24. Administrative Workflow

Admin Login → Authentication → RBAC Authorization → Admin Dashboard → Patient Management → Create/Edit/Delete → Approval → Audit Logging → Reporting → Logout.

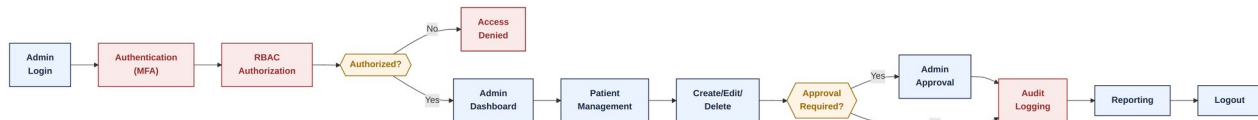


Figure 24.1 — Administrative Workflow with Authorization Gate

24.1 Workflow Notes

- RBAC Authorization functions as a gate immediately after authentication: unauthorized users are denied and logged before ever reaching the Admin Dashboard.
- Not every Create/Edit/Delete action requires approval — the Approval step is conditional, per the approval-workflow rules defined in Section 5.2 (FR-ADM-009).
- Every path — approved or not — passes through Audit Logging before Reporting, ensuring no administrative action bypasses the audit trail.

25. RBAC Workflow

User → Authentication → Identity Verification → Role Determination → Permission Evaluation → Resource Access → Audit Logging.

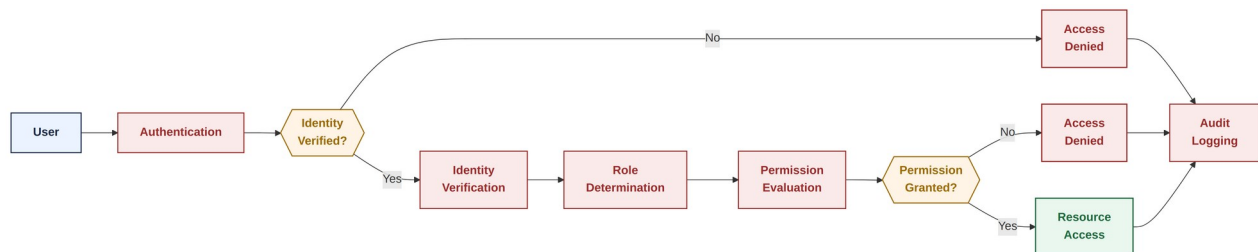


Figure 25.1 — RBAC Workflow with Explicit Denial Paths

25.1 How Unauthorized Access Is Denied

- Authentication Failure: if credentials or multi-factor verification fail, the request is denied immediately ("Access Denied — Failed Authentication") and logged; the request never reaches role or permission evaluation.
- Permission Evaluation Failure: an authenticated user whose role lacks the specific permission for the requested resource is denied at the Permission Evaluation stage ("Access Denied — Unauthorized Access Attempt") and logged, without reaching Resource Access.
- Fail-Closed Default: absent an explicit permission grant for a role/resource combination, access defaults to denied rather than allowed.
- Every denial — like every grant — is captured in Audit Logging with actor, attempted resource, and result, supporting security monitoring and compliance review (Section 12).

26. Responsible AI Workflow

User Request → Authorization → Data Classification → PII/PHI Protection → AI Prompt Processing → LLM/AI Service (RAG) → AI Output → Safety Validation → Accuracy Validation → Human Review → Administrative/Clinical Approval → Approved Output → Audit Logging → Monitoring.



Figure 26.1a — Responsible AI Workflow (1 of 3): Request through AI Output

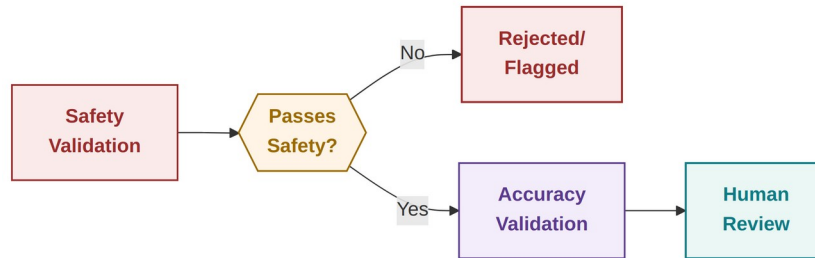


Figure 26.1b — Responsible AI Workflow (2 of 3): Safety Validation through Human Review

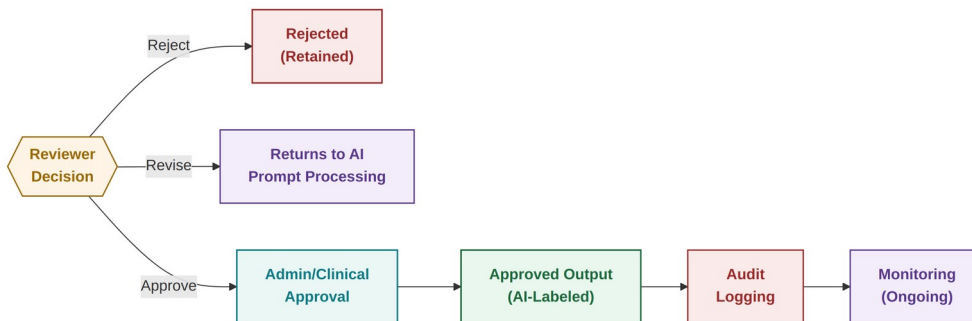


Figure 26.1c — Responsible AI Workflow (3 of 3): Reviewer Decision through Monitoring

26.1 AI Cannot Independently Make High-Risk Clinical Decisions

This workflow has no path from AI Output directly to Approved Output. Every generated draft must pass automated Safety Validation, automated Accuracy Validation, qualified Human Review, and Administrative/Clinical Approval before it is usable. A Reject or Revise decision at Human Review routes the content back into the pipeline or discards it — it never proceeds to publication unreviewed. This mirrors the AI Safety boundary established in Section 15: diagnosis, treatment, medication, and admission/discharge decisions remain exclusively with qualified human staff.

27. Data Flow Architecture

The data flow architecture separates the primary operational data flow from the PII/PHI privacy-specific flow, which converge at the Secure Data Layer and Audit Logging respectively.

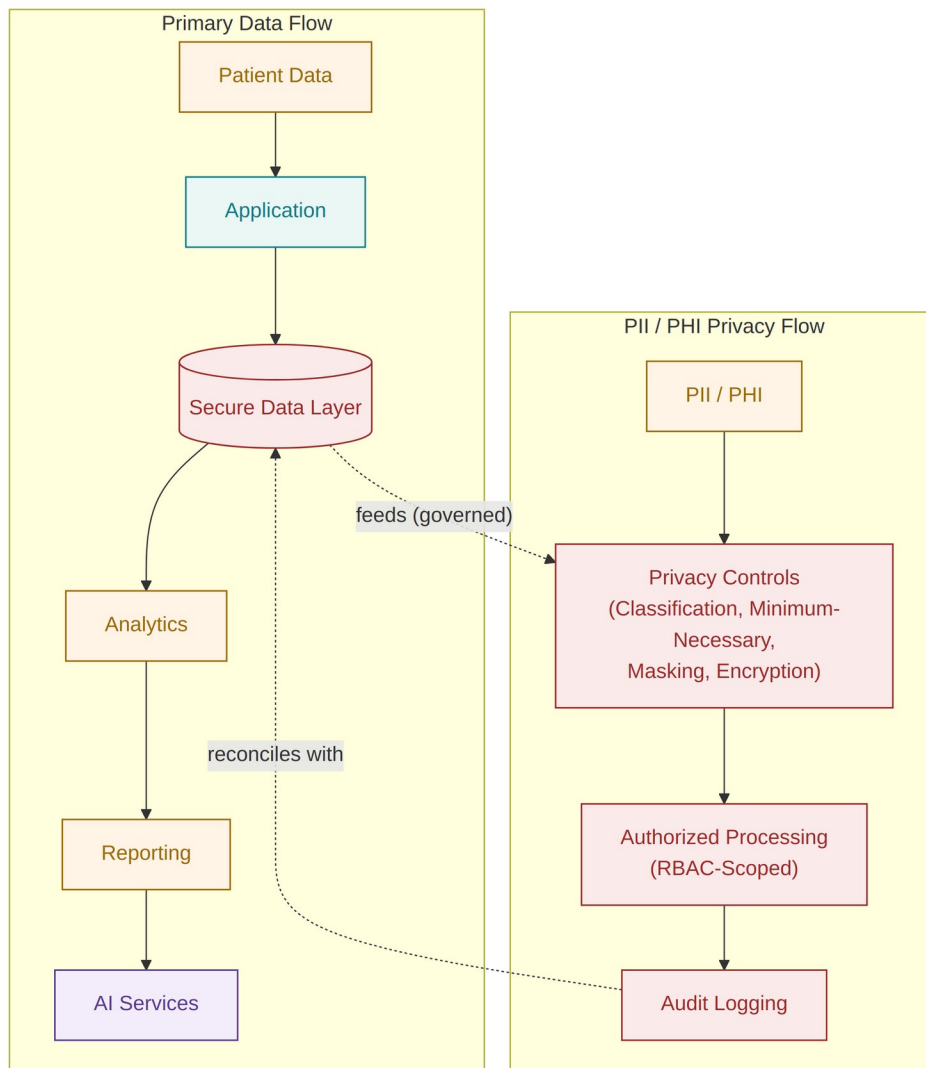


Figure 27.1 — Data Flow Architecture: Primary Flow and PII/PHI Privacy Flow

27.1 Primary Data Flow

Patient Data → Application → Secure Data Layer → Analytics → Reporting → AI Services. Each transition is access-controlled and, from the Secure Data Layer onward, analytics and reporting operate on de-identified or aggregated derivatives wherever the use case allows.

27.2 PII/PHI Privacy Flow

PII/PHI → Privacy Controls (classification, minimum-necessary scoping, masking, encryption) → Authorized Processing (RBAC-scoped) → Audit Logging. This flow feeds into the Secure Data Layer under governed conditions and reconciles with it for consistency and audit completeness.

28. Replit Integration Architecture

This section documents the conceptual relationship among the parties and systems involved in developing and governing the platform. It does not include Replit implementation code.

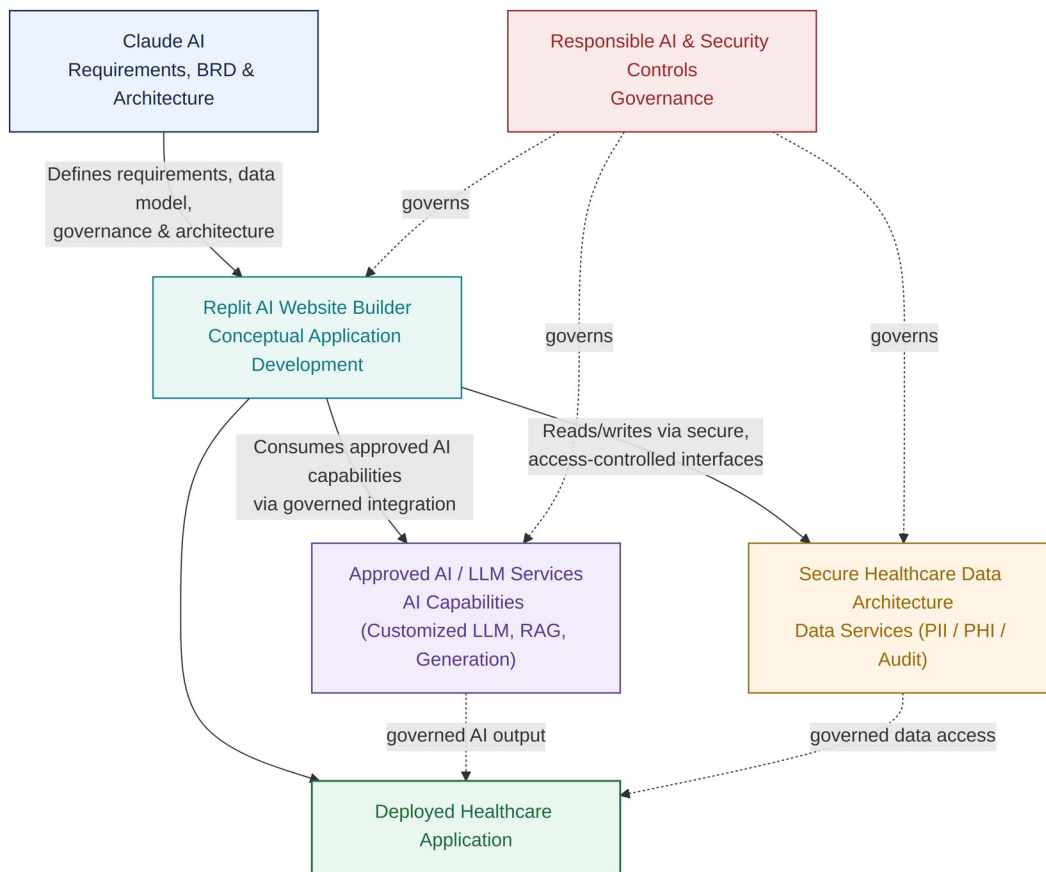


Figure 28.1 — Conceptual Relationship: Claude AI, Replit AI Website Builder, AI/LLM Services, Data Architecture, and Governance

PARTY / SYSTEM	ROLE	RELATIONSHIP TO THE OTHERS
Claude AI	Requirements analysis, BRD authorship, enterprise architecture, workflow and data modeling, Responsible AI framework documentation.	Supplies the requirements, data model, and governance definitions Replit builds against.
Replit AI Website Builder	Conceptual application development of the presentation and application layers.	Consumes approved AI capabilities and secure data services through governed interfaces; does not define governance policy itself.
Approved AI / LLM Services	Provides the AI capabilities described in Sections 17–18 (Customized LLM, RAG, generation, narration).	Operates under AI Governance policy; returns only validated/approved output to the application.
Secure Healthcare Data Architecture	Provides data services (PII/PHI storage, audit logging) per Sections 9–13.	Enforces encryption, RBAC, and audit requirements independent of which layer calls it.
Responsible AI & Security Controls	Governs all of the above per Sections 9–19.	Cross-cutting; not a build-time dependency but a continuous operating constraint.

29. Customized LLM Architecture

Healthcare Knowledge Sources → Data Processing → Knowledge Repository → Retrieval Layer/RAG → Customized LLM → AI Orchestration → Safety & Validation → Human Approval → Application.

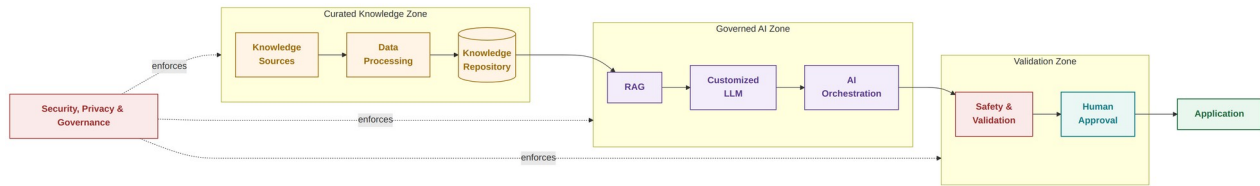


Figure 29.1 — Customized LLM Architecture with Security, Privacy, and Governance Boundaries

29.1 Boundary Summary

- **Curated Knowledge Zone:** Healthcare Knowledge Sources, Data Processing, and the Knowledge Repository are version-controlled and classified per Section 10.2, kept separate from live patient records.
- **Governed AI Zone:** the Retrieval Layer/RAG, Customized LLM, and AI Orchestration operate only on minimum-necessary, request-scoped context (Section 18.2) and have no direct write-access to patient records.
- **Validation & Governance Zone:** Safety & Validation and Human Approval enforce the same pipeline defined in Section 16 before anything reaches the Application.
- **Security, Privacy & Governance** is enforced across all three zones — this is the same cross-cutting control shown in the enterprise architecture (Section 21), applied specifically to the AI subsystem.

30. Architectural Principles

The following fourteen principles govern every architectural decision in this document and should be used as evaluation criteria for any future design or vendor choice.

PRINCIPLE	APPLICATION IN THIS ARCHITECTURE
Security by Design	Security controls (encryption, RBAC, audit) are built into each layer from the outset, not added after the fact.
Privacy by Design	PII/PHI classification, minimum-necessary scoping, and masking are default behaviors, not opt-in features.
Responsible AI by Design	Every AI capability is scoped, validated, and governed per Sections 14–19 before it is built, not retrofitted afterward.
Zero Trust	No request is implicitly trusted based on network location; every call is authenticated and authorized at each boundary (Section 21.1).
Least Privilege	Roles and services receive only the access required for their function (Sections 11, 18.2).
Defense in Depth	Multiple independent layers of control (network, application, data, AI validation) so no single control failure exposes PHI or enables an unsafe AI output.
Human-in-the-Loop	No high-risk clinical or AI-generated content is finalized without qualified human review and approval (Sections 15–16, 26).
Data Minimization	Only the data necessary for a given function or AI request is collected, displayed, or passed into context (Sections 10.1, 18.2).

PRINCIPLE	APPLICATION IN THIS ARCHITECTURE
Auditability	Every sensitive action across every layer produces a traceable, attributable audit record (Section 12).
Interoperability	Data models and APIs are structured to support future integration with external clinical/administrative systems (Section 6, NFR-Interoperability).
Scalability	The layered architecture supports growth in users, patient volume, and data volume without structural redesign (Section 2.13).
Modularity	Layers and services are loosely coupled (e.g., AI Layer is request-scoped, not embedded), enabling independent evolution of each layer.
Resilience	Backup, replication, and recovery requirements (Section 13) ensure continued operation and data durability under disruption.
Observability	Monitoring, logging, and model-performance tracking (Sections 6, 14.9–14.10) provide continuous visibility into system and AI behavior.

31. Architecture Decision Matrix & Executive Summary

31.1 Architecture Decision Matrix

ARCHITECTURE AREA	RECOMMENDED APPROACH	BUSINESS RATIONALE	SECURITY CONSIDERATION	SCALABILITY CONSIDERATION	HEALTHCARE/AI CONSIDERATION
Presentation Layer	Responsive web application with role-scoped interfaces (public, patient, clinical, admin, AI, reporting).	Single platform reduces training overhead and duplicate UI investment.	Public and authenticated zones are structurally separated (Section 21.1).	Modular interface components support future native mobile clients.	Distinct AI Interface keeps AI-generated content visibly separate from clinical system-of-record views.
Application Layer	Domain-separated services (Patient, Ops, Admin, Workflow, AI, Reporting) behind a common authentication/authorization gate.	Clear ownership per domain simplifies governance and change management.	Centralized RBAC/auth enforcement avoids inconsistent per-service access logic.	Services scale independently based on load (e.g., reporting vs. transactional patient ops).	Workflow Management enforces the approval and validation gates required by Sections 16 and 24.
AI Layer	Request-scoped orchestration over a governed Customized LLM with RAG grounding; no standing agent access to records.	Accelerates education/reporting drafting without new clinical liability.	No direct write-access to patient records; all output passes validation (Section 16).	AI Orchestration can add capabilities (e.g., new content types) without redesigning core data flows.	Risk-tiered governance matrix (Section 19.1) scales oversight to capability risk.
Data Layer	Classified, encrypted data stores segmented by sensitivity (PII/PHI vs. de-identified analytics) (Section 10.2).	Protects the institution's most valuable and sensitive asset — patient trust and data integrity.	Encryption at rest/in transit, RBAC-scoped access, full audit trail (Sections 9–10).	Segmentation allows analytics/reporting workloads to scale independently of transactional PHI stores.	AI Knowledge Repository is isolated from live patient records, reducing PHI exposure to AI components.
Security Layer	Cross-cutting identity, RBAC, encryption, audit, monitoring, and threat detection enforced at	Consistent security posture regardless of entry point	Zero Trust and Defense in Depth applied uniformly (Section 30).	Centralized security services scale with the platform rather	Shared foundation for both clinical data protection and AI governance

ARCHITECTURE AREA	RECOMMENDED APPROACH	BUSINESS RATIONALE	SECURITY CONSIDERATION	SCALABILITY CONSIDERATION	HEALTHCARE/AI CONSIDERATION
	every layer (Section 20.5).	reduces institutional risk.		than being duplicated per module.	enforcement.
Integration Approach (Replit / Claude AI)	Claude AI defines requirements/architecture/governance; Replit AI Website Builder conceptually implements against them; AI/LLM and data services are consumed, not embedded (Section 28).	Separates requirements/governance authority from implementation tooling, reducing lock-in risk.	Governance is defined independently of the build tool, so security requirements survive a future platform change.	Conceptual architecture is tool-agnostic and can be re-implemented on other platforms as the institution grows.	Keeps AI governance and clinical safety requirements authoritative over any specific builder's defaults.

31.2 Executive Summary: Why This Architecture Fits a Modern Global Healthcare Institution

This architecture is deliberately layered and boundary-driven rather than monolithic. Separating presentation, application, AI, data, and security concerns — with security and governance enforced as cross-cutting controls rather than a single gate — allows the institution to scale each concern independently: patient volume growth stresses the data and application layers, while new AI capabilities stress only the AI layer's orchestration and governance surface. This isolation limits the blast radius of both technical failures and AI-related incidents.

For a global healthcare institution, three properties matter most: patient data must remain protected and auditable everywhere it travels; AI must accelerate staff and patient-facing work without ever assuming clinical authority; and the platform must be able to grow — in users, facilities, and capabilities — without repeated architectural rework. This design addresses all three directly: PHI/PII classification and encryption are enforced at the data layer and inherited by every consumer, including AI (Sections 9–10, 18.5); no AI output reaches a patient or clinical workflow without automated validation and qualified human approval (Sections 15–16, 26); and the layered, modular structure (Section 30) — together with a build approach that keeps governance independent of any single implementation tool (Section 28) — gives the institution a foundation that can extend to multi-facility, multi-region operation (Section 3.3) without re-architecting its security or AI governance model.

Document Approval

This volume is submitted for executive review and sign-off by the stakeholders below prior to advancement into detailed design and engineering.

ROLE	NAME	SIGNATURE	DATE
Executive Sponsor			
Chief Information Officer			
Chief Technology Officer			

ROLE	NAME	SIGNATURE	DATE
Chief Information Security Officer			

This concludes Volume III of the Business Requirements Document. Application source code and implementation scripts are out of scope for this volume.